

Sparkcat Trojan Attack

Student Eva Kan
Promotor Ruslan Davletov

Introduction

Imagine that you download a seemingly useful app from an official app store, like a photo editor or a financial helper. You trust it because it is on the official store. But secretly, the app is malicious and designed to steal your sensitive information. This is a typical example of a mobile Supply-Chain Attack.

The SparkCat Trojan is a perfect example. It was a family of malicious apps that snuck into both the Apple App Store and the Google Play Store by disguising itself as legitimate software. Its main goal was to steal users' cryptocurrency and other login credentials. This case is highly relevant because it shows that even trusted sources such as official app stores can be compromised, making everyone vulnerable.

In simple terms: attackers poisoned the "water supply" (the app stores) that everyone drinks from, instead of targeting individual "glasses of water" (users)!

Attack Steps

We can break down the attack into clear steps and map them to the MITRE ATT&CK® framework.

1. **Step 1: Infiltration (MITRE: Initial Access):** Attackers created fake, useful-looking apps with names like "ChatAI" and "ComeCome - Chinese Food Delivery" and submitted them to the official app stores. Users unknowingly downloaded a Trojan horse, thinking that it was safe.
2. **Step 2: Deception (MITRE: Defense Evasion):** The apps hid their malicious code, passing the initial app store reviews. They used common names and icons to look legitimate, exploiting the user's trust in the app store. The Trojan behaved differently depending on the app it is running in. The malicious SDK was obfuscated enough to bypass automated security checks during app review.
3. **Step 3: Activation (MITRE: Execution & Persistence):** Once installed, the app would ask for permission to access the device's gallery. By granting permission, users gave the Trojan full control over their sensitive photos information.
4. **Step 4: Theft (MITRE: Collection & Credential Access):** The Trojan used an OCR (Optical Character Recognition) module (based on Google's ML Kit) to scan images for text. This made SparkCat significantly more advanced than typical malware that simply steals files. Depending on the device's language settings, SparkCat downloads models trained to detect the relevant script in photos, whether Latin, Korean, Chinese, or Japanese. Then it applied filters: keywords (for example "Mnemonic", "Recovery phrase", etc) in various languages, dictionary matching, minimum/maximum word lengths, etc. It specifically targeted crypto wallet screens, passwords, and 2FA codes - images that contained such valuable text were identified and flagged for exfiltration.
5. **Step 5: Exfiltration (MITRE: Exfiltration):** The stolen data was sent to a server controlled by the attackers. The attackers then had the keys to the user's digital wallets and accounts, leading to direct financial theft.

Victims and Assets

Victims

The victims were Android and iOS users. They wrongly put their trust in official app services - the apps containing this malicious code were downloaded 250,000 times. If we categorize, the victims were

- *Individual Users:* Anyone who downloaded the malicious apps, particularly people interested in cryptocurrency.
- *Organizations:* Employees who installed these apps on company-owned phones created risks for corporate data exposure.

- **App Stores (Apple & Google):** Their reputations were damaged because users trust their security review processes.

Assets Impacted & Associated Risks:

- *Cryptocurrency Wallets:* The primary target. The risk is a direct financial loss; once crypto is stolen, it is almost impossible to recover.
- *Login Credentials:* For social media, banking, and email accounts. The risk is identity theft and account takeover.
- *Two-Factor Authentication (2FA) Codes:* By reading these codes, attackers bypassed this critical security layer, making all protected accounts vulnerable.
- *Personal Data:* Any other information on the phone. The risk is invasion of privacy and the use of data for blackmail or phishing.

Defense Recommendations

Based on analysis from security vendors like Kaspersky, in this case the practical steps for individuals and organizations are:

Best Practices:

1. *Practice "Zero Trust":* Don't trust an app just because it's on an official store. Check the developer's name, read reviews, and look for typos or poor grammar.
2. *Scrutinize App Permissions:* Pay attention to gallery/photo access permissions in particular - do not grant it unless it's for a clear, legitimate purpose.
3. *Use Hardware Wallets:* For significant cryptocurrency holdings, use a dedicated hardware wallet. These never expose your private keys to your phone.
4. *Keep Software Updated:* Always update your phone's operating system and apps. Updates often include security patches.

Frameworks & Policies:

1. *Mobile Device Management (MDM):* Use MDM software to control which apps employees can install on company devices.
2. *Security Awareness Training:* Teach employees how to recognize suspicious apps and the dangers of careless permission granting.
3. *Application Allowlisting:* Create a list of pre-approved apps that employees are allowed to install.
4. *Adopt a Security Framework:* Follow frameworks like the NIST Cybersecurity Framework to systematically Identify, Protect, Detect, Respond, and Recover from threats.

Role-Based Conclusion

My Role: I am a Penetration Tester (Pentester) hired to think like an attacker and find weaknesses in a company's defenses before a real hacker does.

If I had been testing the company before the SparkCat attack, here's how we could have prevented or minimized the damage:

How It Could Have Been Prevented:

- *Simulated Phishing and Social Engineering:* I would have run tests sending fake emails encouraging employees to download a malicious app. This would have revealed which employees needed more training.
- *Technical Control Testing:* I would have verified that the company's Mobile Device Management (MDM) system was properly configured to block installation of apps that are not on the corporate allowlist.

How the Damage Could Have Been Minimized:

- *Segmentation of Networks*: I would recommend creating a separate Wi-Fi network for personal devices to prevent infected personal devices from interacting with internal systems.
- *Enhanced Monitoring*: I would advise implementing security tools that monitor for unusual network traffic, like a phone suddenly sending large amounts of data to an unknown server overseas.

The key lesson from SparkCat is that user trust is a vulnerability. By combining technology (MDM), policy (application allowlists), and continuous user education, a company can build a robust defense against these clever supply-chain attacks.

References

- [1] "Kaspersky discovers new crypto-stealing Trojan in AppStore and Google Play", Kaspersky.
<https://www.kaspersky.com/about/press-releases/kaspersky-discovers-new-crypto-stealing-trojan-in-appstore-and-google-play>
- [2] "Take my money: OCR crypto stealers in Google Play and App Store", Securelist.
<https://securelist.com/sparkcat-stealer-in-app-store-and-google-play/115385/>
- [3] "Kaspersky Discovers New Crypto-Stealing Trojan "SparkCat" in AppStore and Google Play", Tech-ish.
<https://tech-ish.com/2025/02/05/kaspersky-discovers-new-crypto-stealing-trojan-sparkcat-in-appstore-and-google-play/>
- [4] "iOS & Android OCR stealer: how we caught Sparkcat", Kaspersky Blog.
<https://www.kaspersky.com/blog/ios-android-ocr-stealer-sparkcat/52980/>